FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

Fictional Retail Group (mixed controls) has useful foundations in fraud leadership and governance, but weak digital and identity fraud risk and third-party and supply chain fraud risk leave fraud readiness largely developing.

70.84 / 100 **DEVELOPING**

PREPARED FOR

Fictional Retail Group (mixed controls)

Assessment reference · FX-P3

Assessment date · 11 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL RETAIL GROUP (MIXED CONTROLS)

WHAT DOES THE ASSESSMENT SHOW?

Fraud readiness at a glance

70.84	Developing	10	90.67	21.08
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	STRONGEST DOMAIN	WEAKEST DOMAIN
			Fraud Leadership & Governance	Digital & Identity

Domain readiness profile

Digital and Identity Fraud Risk	21.08	Reactive
Third-Party and Supply Chain Fraud Risk	34.71	
Operational Fraud Controls	58.10	Developing
Fraud Culture and Awareness	85.56	Strategic
Fraud Detection Capability	87.06	
Fraud Incident Response	87.69	
Whistleblowing and Reporting Culture	88.33	
Fraud Risk Identification	89.74	
Continuous Improvement and Fraud Risk Monitoring	90.48	
Fraud Leadership and Governance	90.67	

Ordered weakest first. Overall readiness 70.84 / 100.

Material capability relationships

Operational Fraud Controls	58.1
Third-Party and Supply Chain Fraud Risk	34.71

GAP 23.39 POINTS

The pattern suggests operational control does not yet extend consistently into third-party and supply-chain exposure.

WHY DOES THE POSITION LOOK LIKE THIS?

What is driving the position

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Fraud governance and risk discipline	Fraud Risk Identification **89.74** Continuous Improvement and Fraud Risk Monitoring **90.48** Fraud Leadership and Governance **90.67**	The reported cycle of ownership, assessment and review holds only while it stays current, evidenced and connected to management decisions.
Supplier and payment integrity	Third-Party and Supply Chain Fraud Risk **34.71** Operational Fraud Controls **58.1**	Operational controls do not extend consistently to supplier onboarding and payment-change challenge, leaving direct value-diversion exposure.
Monitoring and detection coverage	Digital and Identity Fraud Risk **21.08** Fraud Detection Capability **87.06** Continuous Improvement and Fraud Risk Monitoring **90.48**	Unusual activity may not be challenged early enough, allowing exposure to remain below management attention.
Incident response and evidence integrity	Fraud Culture and Awareness **85.56** Fraud Incident Response **87.69** Whistleblowing and Reporting Culture **88.33**	Reporting, preservation and response are reported as operating; the management question is whether they would hold under a live incident and produce defensible evidence.

WHERE DOES FRAUD EXPOSURE MATTER MOST?

Priority fraud exposure

#	PRIORITY EXPOSURE	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	PRIORITY ORDER
1	**Weak challenge at identity, transaction and sensitive-change points** Identity verification at material risk points is not yet applied consistently enough to prevent misuse.	Digital and Identity Fraud Risk **21.08**	Unauthorised access, payment, benefit or profile change can occur before the identity or transaction is challenged.	A defined monitoring cycle with named exception review.	**Priority 1** Digital and Identity Fraud Risk scores 21.08, the weakest capability supporting this exposure.
2	**Value diversion through supplier and payment processes** Supplier bank-detail changes are not yet consistently verified through a trusted independent channel before payment.	Third-Party and Supply Chain Fraud Risk **34.71** Operational Fraud Controls **58.1**	A diverted payment or fictitious supplier relationship can create financial loss and delayed recovery.	Independent verification before a supplier or bank change takes effect.	**Priority 2** Third-Party and Supply Chain Fraud Risk scores 34.71, the weakest capability supporting this exposure.

Ordered by the weakest capability supporting each exposure. The order indicates where to act first; it is not a risk rating, and closely ranked exposures may warrant similar attention.

HOW COULD THAT EXPOSURE MATERIALISE?

How exposure could materialise

Supplier or payment instruction is diverted through a compromised or fictitious relationship

Bank-detail or supplier change submitted › Independent verification absent or bypassed › Legitimate payment redirected before challenge

An actor submits a credible-looking bank-detail change and relies on the same team both accepting and approving it to divert a genuine payment.

Interrupted by: Hold the change, call back on a trusted number, require a second approval.

Warning signs: An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. · Any engagement before due diligence or unresolved ownership, sanctions or conflict match. · Any supplier activated before verification or any ownership/conflict match unresolved.

Unusual activity avoids timely challenge because monitoring or escalation coverage is incomplete

Activity structured to stay below review thresholds › No repeatable monitoring or timely exception review › Suspicious activity accumulates unchallenged

An actor keeps refunds, credits or adjustments individually small and routine so they remain below or outside the available monitoring and exception thresholds.

Interrupted by: Define exception populations, named reviewers and overdue escalation.

Warning signs: An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. · Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated. · Repeated low-value or threshold-adjacent activity

These are plausible fraud pathways derived from the assessment. They are not allegations that these events have occurred.

WHAT DOES MANAGEMENT NEED TO CHANGE?

What management should change

#	MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
2	**Independent supplier verification before activation**	Supplier onboarding verifies identity, ownership, banking and conflicts before activation.	Finance / operations accountable owner	Independent challenge applies before activation or payment across supplier-master changes, bank-detail amendments and new supplier activation, with a trusted-channel callback, second approval and a retained verification record.
3	**Role-based access and segregation of duties**	Role-based access and segregation are aligned to current responsibilities and reviewed for exceptions.	Finance / operations accountable owner	Access follows current role responsibilities, with segregation-of-duties conflicts identified, justified or removed on a defined cycle.
4	**Restricted and recertified privileged access**	Privileged access is restricted, logged, recertified and removed when no longer justified.	Technology / security accountable owner	Privileged accounts are named, restricted to justified need, logged, recertified on a defined cycle and removed when the justification ends.
5	**Repeatable monitoring and named exception review**	Fraud monitoring and exception review operate with defined coverage, ownership, closure evidence and escalation.	Technology / security accountable owner	Monitoring extends beyond fraud leadership and governance into supplier-master changes; sensitive identity and account changes; bank-detail amendments, with defined exception populations, named reviewers and overdue escalation.

WHAT SHOULD HAPPEN IN THE FIRST 90 DAYS?

The first 90 days

30 days: Stabilise

0–30 DAYS

Supplier payment and bank-detail changes are independently verified before release.

Quarantine bank-detail changes, callback to a trusted pre-existing contact and require segregated approval.

Finance / operations accountable owner

Quarantine bank-detail changes, callback to a trusted pre-existing contact and require segregated approval.

Complete when: Bank-detail-change request

60 days: Establish

31–60 DAYS

Supplier onboarding verifies identity, ownership, banking and conflicts before activation.

Independent supplier verification before activation

Finance / operations accountable owner

Implement independent legal-identity, ownership, banking and conflict checks before supplier activation.

Complete when: Beneficial-ownership/conflict screening

Role-based access and segregation of duties

Finance / operations accountable owner

Reconcile role-based access and segregation-of-duties exceptions against current responsibilities.

Complete when: Access requests and approvals

Restricted and recertified privileged access

Technology / security accountable owner

Reconcile the privileged-account population, enforce named access and retain periodic recertification evidence.

Complete when: Approval and business justification

90 days: Operate and review

61–90 DAYS

Fraud monitoring and exception review operate with defined coverage, ownership, closure evidence and escalation.

Repeatable monitoring and named exception review

Technology / security accountable owner

Define monitoring coverage, red flags, review ownership, closure evidence and overdue escalation.

Complete when: Alert case records

Verification at identity and sensitive-change points

Technology / security accountable owner

Apply risk-based identity verification and controlled review of sensitive profile or account changes.

Complete when: Alert definitions for takeover indicators

HOW WILL MANAGEMENT KNOW WHETHER READINESS IS IMPROVING?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Independent supplier verification before activation	Partially designed: Partially designed but not fully implemented.; assessed from management responses.	Independent challenge applies before activation or payment across supplier-master changes, bank-detail amendments and new supplier activation, with a trusted-channel callback, second approval and a retained verification record.
Role-based access and segregation of duties	Partially designed: Partially designed but not fully implemented.; assessed from management responses.	Access follows current role responsibilities, with segregation-of-duties conflicts identified, justified or removed on a defined cycle.
Restricted and recertified privileged access	Not assessed	Privileged accounts are named, restricted to justified need, logged, recertified on a defined cycle and removed when the justification ends.
Repeatable monitoring and named exception review	Not in place: No control exists.; assessed from management responses.	Monitoring extends beyond fraud leadership and governance into supplier-master changes; sensitive identity and account changes; bank-detail amendments, with defined exception populations, named reviewers and overdue escalation.

Management conclusion

Fictional Retail Group (mixed controls) is not starting from zero. Its fraud leadership and governance and continuous improvement and fraud risk monitoring provide a useful foundation. The weakness is that these capabilities are not yet connected into a repeatable fraud-risk cycle, so ownership, challenge, detection and response do not yet reinforce one another. The next 90-day checkpoint should test whether ownership now operate as one system rather than as separate activities.

This report is based on management's responses to the MK Fraud Readiness assessment and MK's analytical methodology. It provides fraud-risk analysis and control-design guidance. MK has not independently tested whether controls operate in practice.